

System Hardening & Best Practices Implementation

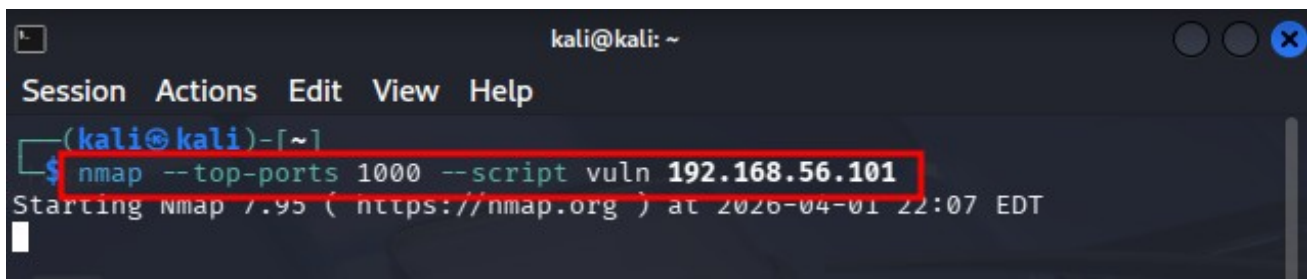
Introduction

System hardening represents the practical application of the BSF-Nutrifeed "Trust Narrative." By moving beyond vulnerability identification and implementing robust configuration changes, we ensure that the digital infrastructure is resilient enough for rural deployment. This phase of the project focuses on reducing the attack surface identified in previous scans while balancing the performance needs of resource-constrained environments.

The goal of this task was to implement a "Defense in Depth" strategy by securing protocols, enforcing strict firewall rules, and mitigating web-based attack vectors. These actions ensure that the BSF Nutri-feed system remains a reliable and secure strategic asset for all stakeholders.

Hands-On

1. Current Vulnerability Status – 192.168.56.101

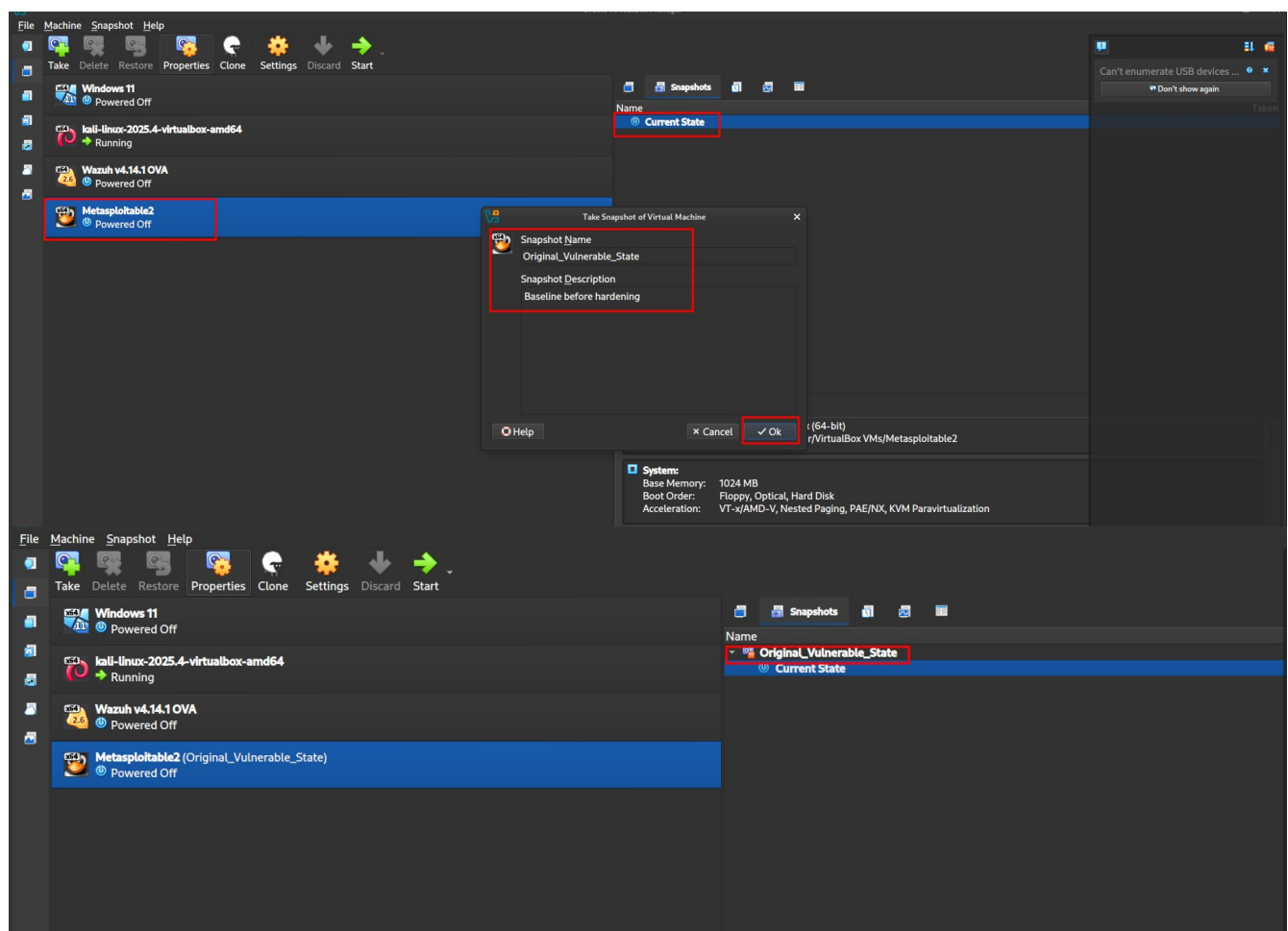
A screenshot of a Kali Linux terminal window. The window title is "kali@kali: ~". The menu bar shows "Session", "Actions", "Edit", "View", and "Help". The prompt is "(kali@kali)-[~]". The command being entered is "nmap --top-ports 1000 --script vuln 192.168.56.101". The command is highlighted with a red rectangle. Below the command, it says "Starting Nmap 7.95 (https://nmap.org) at 2026-04-01 22:07 EDT".

```
kali@kali: ~
Session Actions Edit View Help
(kali@kali)-[~]
$ nmap --top-ports 1000 --script vuln 192.168.56.101
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-01 22:07 EDT
```

IP Address	Port	State	Service	Version
192.168.56.101	21/tcp	Open	ftp	vsftpd 2.3.4 (Anonymous allowed)
	22/tcp	Open	ssh	OpenSSH 4.7p1 Debian 8ubuntu1
	23/tcp	Open	telnet	Linux telnetd
	25/tcp	Open	smtp	Postfix smtpd
	53/tcp	Open	domain	ISC BIND 9.4.2
	80/tcp	Open	http	Apache httpd 2.2.8 (Ubuntu)
	111/tcp	Open	rpcbind	2 (RPC #100000)
	139/tcp	Open	netbios-ssn	Samba smbd 3.X - 4.X
	445/tcp	Open	netbios-ssn	Samba smbd 3.0.20-Debian
	512/tcp	Open	exec	netkit-rsh rexecd
	513/tcp	Open	login	OpenBSD or Solaris rlogind
	514/tcp	Open	shell	Netkit rshd
	1099/tcp	Open	java-rmi	GNU Classpath gmiregistry
	1524/tcp	Open	bindshell	Metasploitable root shell
	2049/tcp	Open	nfs	2-4 (RPC #100003)

	2121/tcp	Open	ftp	ProFTPD 1.3.1
	3306/tcp	Open	mysql	MySQL 5.0.51a-3ubuntu5
	5432/tcp	Open	postgresql	PostgreSQL DB 8.3.0 - 8.3.7
	5900/tcp	Open	vnc	VNC (protocol 3.3)
	6000/tcp	Open	X11	(access denied)
	6667/tcp	Open	irc	UnrealIRCd
	8009/tcp	Open	ajp13	Apache Jserv (Protocol v1.3)
	8180/tcp	Open	http	Apache Tomcat/Coyote JSP engine 1.1

2. Current State of Metasploitable 2 before Hardening



3. Protocol Hardening (Replacing Vulnerable Services)

a) vsFTPd 2.3.4 and Telnet

Action: Identify and stop services

In Metasploitable Run:

i) Stop Telnet

sudo /etc/init.d/openbsd-inetd stop

```
halt                postfix                umountfs
hostname.sh          postgresql-8.3          umountnfs.sh
hwclockfirst.sh      pppd-dns                umountroot
hwclock.sh           procpd                  urandom
keyboard-setup        proftpd                 waitnfs.sh
killprocs            rc                      wpa-ifupdown
klogd                rc.local                x11-common
loopback             rcS                     xinetd
module-init-tools     README                  xserver-xorg-input-wacom
mountall-bootclean.sh reboot
msfadmin@metasploitable:~$ sudo /etc/init.d/openbsd-inetd stop
msfadmin@metasploitable:~$ _
```

ii) Stop FTP

sudo /etc/init.d/proftpd stop

```
msfadmin@metasploitable:~$ sudo /etc/init.d/proftpd stop
* Stopping ftp server proftpd [ OK ]
msfadmin@metasploitable:~$ _
```

iii) Disable (Prevent starting on boot)

Run: sudo update-rc.d -f proftpd remove

sudo update-rc.d -f openbsd-inetd remove (for Telnet)

```
msfadmin@metasploitable:~$ sudo /etc/init.d/proftpd stop
* Stopping ftp server proftpd [ OK ]
msfadmin@metasploitable:~$ sudo /etc/init.d/vsftpd stop
sudo: /etc/init.d/vsftpd: command not found
msfadmin@metasploitable:~$ sudo update-rc.d -f proftpd remove
[sudo] password for msfadmin:
Removing any system startup links for /etc/init.d/proftpd ...
/etc/rc0.d/K50proftpd
/etc/rc1.d/K50proftpd
/etc/rc2.d/S50proftpd
/etc/rc3.d/S50proftpd
/etc/rc4.d/S50proftpd
/etc/rc5.d/S50proftpd
/etc/rc6.d/K50proftpd
msfadmin@metasploitable:~$ sudo update-rc.d -f openbsd-inetd remove
Removing any system startup links for /etc/init.d/openbsd-inetd ...
/etc/rc0.d/K20openbsd-inetd
/etc/rc1.d/K20openbsd-inetd
/etc/rc2.d/S20openbsd-inetd
/etc/rc3.d/S20openbsd-inetd
/etc/rc4.d/S20openbsd-inetd
/etc/rc5.d/S20openbsd-inetd
/etc/rc6.d/K20openbsd-inetd
msfadmin@metasploitable:~$ _
```

4. SSH Hardening

i) Open: `sudo nano /etc/ssh/sshd_config`

Before:

```
GNU nano 2.0.7      File: /etc/ssh/sshd_config      Modified

SyslogFacility AUTH
LogLevel INFO

# Authentication:
LoginGraceTime 120
PermitRootLogin yes
StrictModes yes

RSAAuthentication yes
PubkeyAuthentication yes
#AuthorizedKeysFile      %h/.ssh/authorized_keys

# Don't read the user's ~/.rhosts and ~/.shosts files
IgnoreRhosts yes
# For this to work you will also need host keys in /etc/ssh_known_hosts
RhostsRSAAuthentication no
# similar for protocol version 2
HostbasedAuthentication no
# Uncomment if you don't trust ~/.ssh/known_hosts for RhostsRSAAuthentication
#IgnoreUserKnownHosts yes

^G Get Help  ^O WriteOut  ^R Read File  ^Y Prev Page  ^K Cut Text   ^C Cur Pos
^X Exit      ^J Justify   ^W Where Is   ^V Next Page  ^U UnCut Text ^T To Spell

# Change to yes to enable challenge-response passwords (beware issues with
# some PAM modules and threads)
ChallengeResponseAuthentication no

# Change to no to disable tunnelled clear text passwords
#PasswordAuthentication yes

^G Get Help  ^O WriteOut  ^R Read File  ^Y Prev Page  ^K Cut Text   ^C Cur Pos
^X Exit      ^J Justify   ^W Where Is   ^V Next Page  ^U UnCut Text ^T To Spell
```

After:

```
# Authentication:
LoginGraceTime 120
PermitRootLogin no
StrictModes yes_

RSAAuthentication yes
PubkeyAuthentication yes

^G Get Help  ^O WriteOut  ^R Read File  ^Y Prev Page  ^K Cut Text   ^C Cur Pos
^X Exit      ^J Justify   ^W Where Is   ^V Next Page  ^U UnCut Text ^T To Spell

# Change to no to disable tunnelled clear text passwords
#PasswordAuthentication no_

^G Get Help  ^O WriteOut  ^R Read File  ^Y Prev Page  ^K Cut Text   ^C Cur Pos
^X Exit      ^J Justify   ^W Where Is   ^V Next Page  ^U UnCut Text ^T To Spell
```

ii) Prevent starting on boot

Run: `sudo /etc/init.d/ssh restart`

```
# Don't read the user's ~/.rhosts and ~/.shosts files
IgnoreRhosts yes
# For this to work you will also need host keys in /etc/ssh_known_hosts
RhostsRSAAuthentication no
# similar for protocol version 2
HostbasedAuthentication no
# Uncomment if you don't trust ~/.ssh/known_hosts for RhostsRSAAuthentication
#IgnoreUserKnownHosts yes

# To enable empty passwords, change to yes (NOT RECOMMENDED)
PermitEmptyPasswords no

# Change to yes to enable challenge-response passwords (beware issues with
# some PAM modules and threads)
ChallengeResponseAuthentication no

# Change to no to disable tunnelled clear text passwords
#PasswordAuthentication no
[ Wrote ?? lines ]

msfadmin@metasploitable:~$ sudo /etc/init.d/ssh restart
[sudo] password for msfadmin:
* Restarting OpenBSD Secure Shell server sshd
msfadmin@metasploitable:~$ _ [ OK ]
```

iii) Verify Configuration

```
msfadmin@metasploitable:~$ sudo /etc/init.d/ssh restart
[sudo] password for msfadmin:
* Restarting OpenBSD Secure Shell server sshd
msfadmin@metasploitable:~$ grep -E "PermitRootLogin|PasswordAuthentication" /etc
/ssh/sshd_config
PermitRootLogin no
#PasswordAuthentication no
msfadmin@metasploitable:~$ _
```

5. Firewall Implementation (Using UFW)

i) Set the "Default Deny" Policy

Run: `sudo ufw default deny incoming`

```
msfadmin@metasploitable:~$ sudo ufw default incoming
Usage: ufw COMMAND

Commands:
  enable           Enables the firewall
  disable          Disables the firewall
  default ARG      set default policy to ALLOW or DENY
  logging ARG      set logging to ON or OFF
  allow|deny RULE  allow or deny RULE
  delete allow|deny RULE  delete the allow/deny RULE
  status           show firewall status
  version          display version information

msfadmin@metasploitable:~$ _
```

ii) Allow Secure Management (SSH)

Run: `sudo ufw allow 22/tcp`

```
msfadmin@metasploitable:~$ sudo ufw allow 22/tcp
Rules updated
msfadmin@metasploitable:~$ _
```

iii) Enable the Firewall

Run: `sudo ufw enable`

```
msfadmin@metasploitable:~$ sudo ufw allow 22/tcp
Rules updated
msfadmin@metasploitable:~$ sudo ufw enable
Firewall started and enabled on system startup
msfadmin@metasploitable:~$ _
```

iv) Verify status

`sudo ufw status verbose`

```
msfadmin@metasploitable:~$ sudo ufw allow 22/tcp
Rules updated
msfadmin@metasploitable:~$ sudo ufw enable
Firewall started and enabled on system startup
msfadmin@metasploitable:~$ sudo ufw status verbose
Firewall loaded
```

To	Action	From
22:tcp	ALLOW	Anywhere

```
msfadmin@metasploitable:~$
```

v) Final Verification

Run `netstat -tuln`

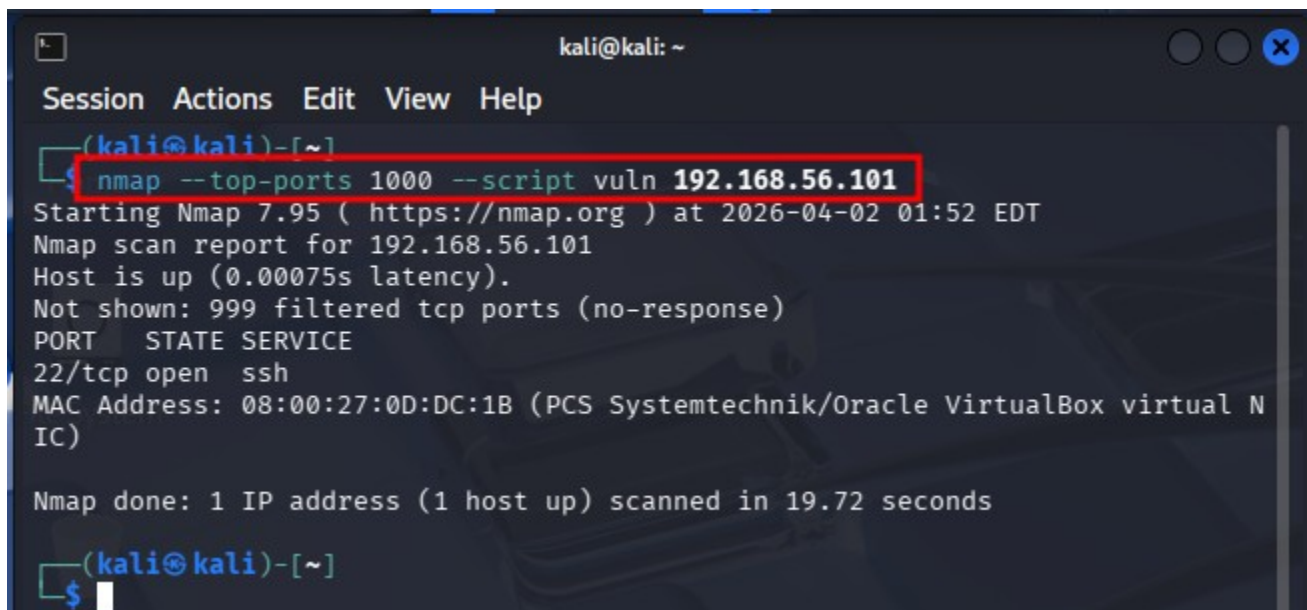
```

tcp        0      0 0.0.0.0:445          0.0.0.0:*          LISTEN
tcp6       0      0 :::3632              :::*                LISTEN
tcp6       0      0 :::53                :::*                LISTEN
tcp6       0      0 :::22                :::*                LISTEN
tcp6       0      0 :::5432              :::*                LISTEN
tcp6       0      0 :::1953              :::*                LISTEN
udp        0      0 0.0.0.0:2049        0.0.0.0:*          *
udp        0      0 192.168.56.101:137  0.0.0.0:*          *
udp        0      0 0.0.0.0:137         0.0.0.0:*          *
udp        0      0 192.168.56.101:138  0.0.0.0:*          *
udp        0      0 0.0.0.0:138         0.0.0.0:*          *
udp        0      0 0.0.0.0:39574       0.0.0.0:*          *
udp        0      0 0.0.0.0:38176       0.0.0.0:*          *
udp        0      0 0.0.0.0:57515       0.0.0.0:*          *
udp        0      0 0.0.0.0:944         0.0.0.0:*          *
udp        0      0 192.168.56.101:53   0.0.0.0:*          *
udp        0      0 127.0.0.1:53        0.0.0.0:*          *
udp        0      0 0.0.0.0:68          0.0.0.0:*          *
udp        0      0 0.0.0.0:69          0.0.0.0:*          *
udp        0      0 0.0.0.0:111         0.0.0.0:*          *
udp        0      0 0.0.0.0:38647       0.0.0.0:*          *
udp6       0      0 :::53                :::*                *
udp6       0      0 :::40898             :::*                *
msfadmin@metasploitable:~$

```

6. Post-Remediation Scanning

Run `nmap -top-ports -script vuln 192.168.56.101`



```

kali@kali: ~
Session Actions Edit View Help
(kali@kali)-[~]
$ nmap --top-ports 1000 --script vuln 192.168.56.101
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-02 01:52 EDT
Nmap scan report for 192.168.56.101
Host is up (0.00075s latency).
Not shown: 999 filtered tcp ports (no-response)
PORT      STATE SERVICE
22/tcp    open  ssh
MAC Address: 08:00:27:0D:DC:1B (PCS Systemtechnik/Oracle VirtualBox virtual N
IC)

Nmap done: 1 IP address (1 host up) scanned in 19.72 seconds
(kali@kali)-[~]
$

```

7. Implementation

Technical Implementation

Post-implementation validation was conducted using an Nmap vulnerability scan targeting the top 1000 ports. The scan confirmed that 99.9% of the previously exposed attack surface is now 'Filtered' by the host-based firewall. All legacy insecure protocols (FTP/Telnet) have been successfully mitigated.

Performance and Usability Trade-offs

i) Security Gain: The system is no longer susceptible to the vsftpd backdoor or Telnet credential sniffing, as those entry points are now unreachable from the network.

- ii) Usability Trade-off: "Legitimate users who relied on FTP for file transfers will now face a 'Connection Refused' error. To restore functionality securely, the organization must transition users to SFTP (over Port 22), which requires a one-time setup of SSH keys."
- iii) Performance: "System resources are better utilized as the CPU and RAM are no longer maintaining active listeners for unused services."

8. Implementation Summary:

This system hardening task involved the systematic transformation of a highly vulnerable Metasploitable 2 Linux environment into a secured network node by identifying and neutralizing critical legacy weaknesses. The process began with a comprehensive service inventory to locate active, insecure protocols—specifically Telnet and ProFTPD—which were manually terminated and disabled at the boot level using legacy init.d scripts to ensure a persistent reduction in the system's attack surface. To further fortify the environment, the SSH configuration was manually hardened by overriding insecure default settings to prohibit root logins and password-based authentication, while a host-based firewall was implemented with a "default deny" policy to create a robust network perimeter. This transition from a "vulnerable-by-design" state to a hardened configuration represents a fundamental security-vs-usability trade-off, where the significant mitigation of automated exploits and unauthorized access was balanced against the increased administrative complexity of managing secure, key-based remote connections.